

HealthGuard AI Project Architecture

Client-ready system architecture, data flow, security, RAG, LLM, and compliance overview

HealthGuard AI is a preventive health intelligence workspace. Patients complete guided assessments, upload optional health documents, use voice intake, and generate educational reports. Doctors and dieticians review patient reports with assignment, comments, signatures, status lifecycle, and patient notifications. Admin and compliance users manage knowledge and audit visibility.

Implemented Stack

FastAPI + Uvicorn
HTML, CSS, JavaScript, Bootstrap
PostgreSQL with SQLite fallback
Gemini LLM, Hugging Face ASR
RAG with pgvector-ready embeddings

Core Capabilities

Verified auth and RBAC
Assessment, risk, diet, activity
Document extraction and RAG
Doctor review workflow
PDF reports and versioning

Compliance Controls

Consent records
Privacy export and deletion
Encrypted PHI payloads
Audit hash chain
Security headers

Current Status

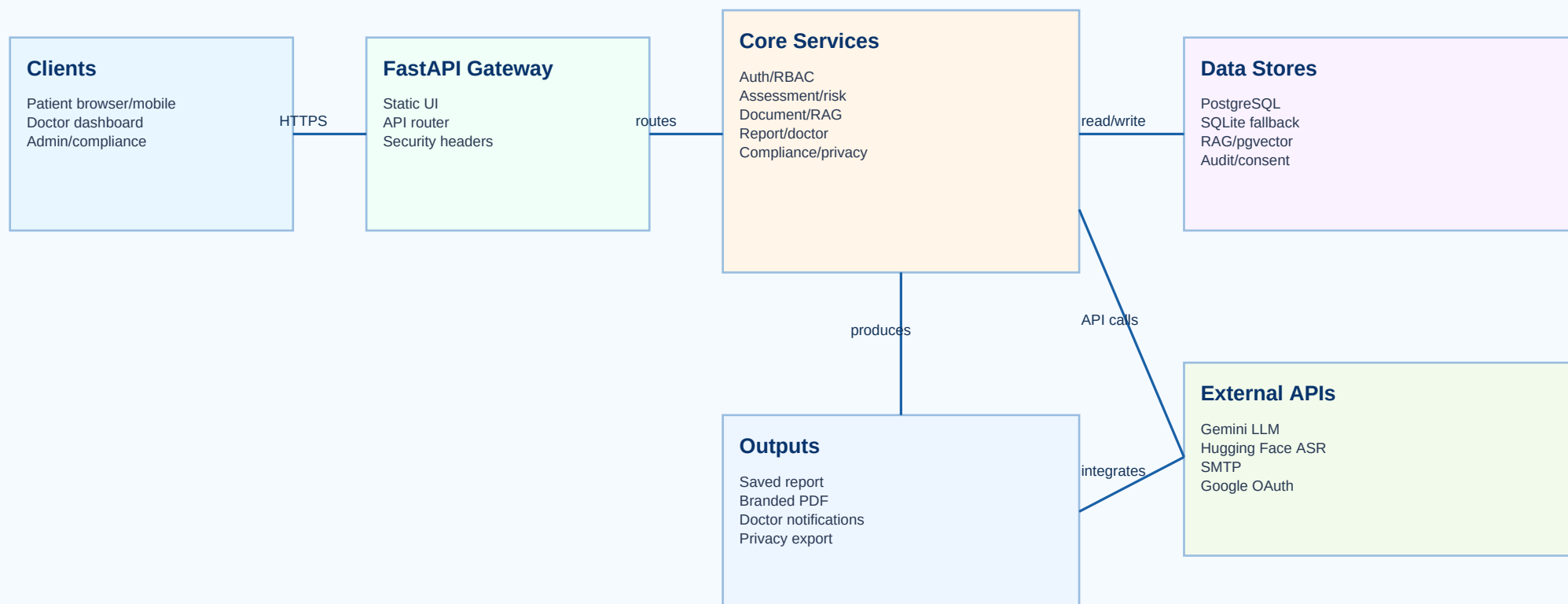
Demo ready: about 85%
Production: about 60%
Healthcare compliance:
about 60%

Architecture Goals

- Keep patient data isolated by authenticated user at API and storage layers.
- Use deterministic safety and risk scoring before LLM enhancement.
- Retrieve only relevant global and user-owned RAG chunks for reports and chat.
- Fail closed when live LLM report generation is configured but unavailable.
- Maintain audit, consent, report versioning, and privacy controls for pilot compliance readiness.

End-to-End Architecture Diagram

Major deployable layers and information flow

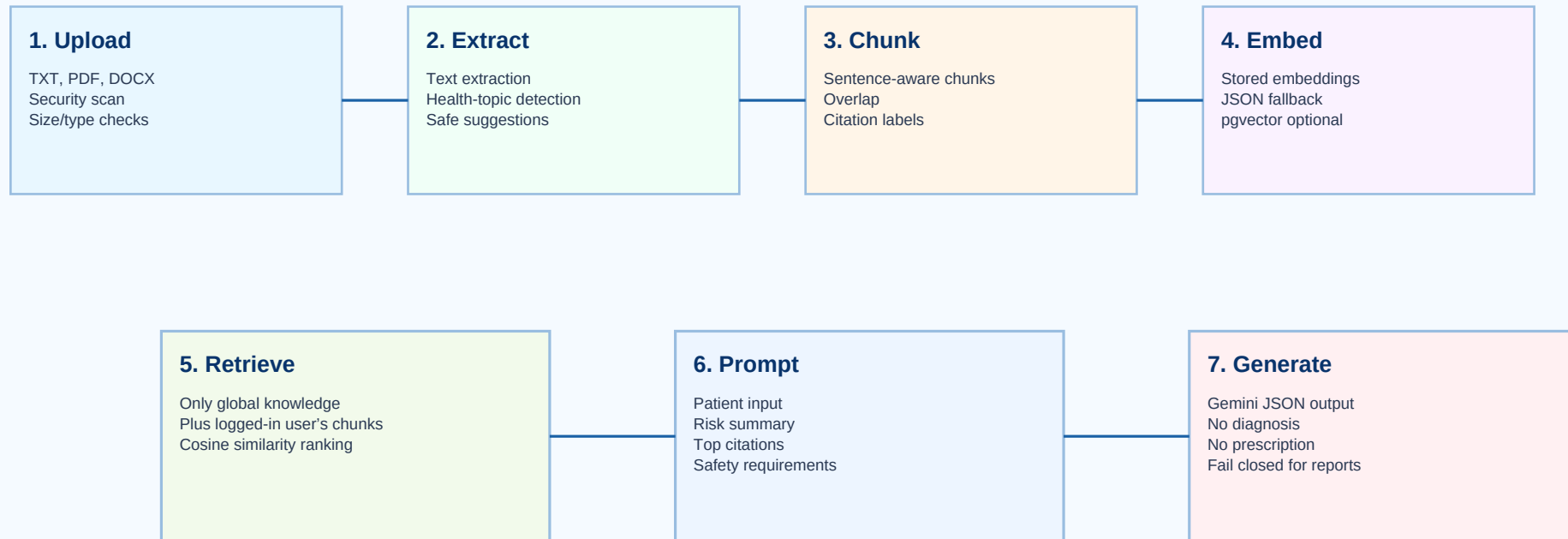


Key Flow

- User request enters the FastAPI router after authentication and email verification.
- Assessment service validates mandatory patient fields and consent.
- Document service scans uploads, extracts text, chunks content, stores embeddings, and indexes per user.
- Report service combines deterministic risk output, RAG citations, and Gemini LLM enhancement.
- Doctor workflow updates report lifecycle and version history; patient receives notifications.

RAG and LLM Orchestration

How uploaded files and knowledge are used safely



RAG Privacy Rule

Patient uploads are tied to `rag_documents.user_id` and `rag_chunks.user_id`. Report and chat retrieval loads global approved knowledge plus only the logged-in patient's document chunks. Other patients' uploaded files are never selected for that user's report context.

Security, Privacy, and Compliance Architecture

Controls that lift pilot-readiness toward healthcare compliance

Access Control

Email verification gate
Signed expiring sessions
Logout revocation
Role-based APIs
Google SSO path

Data Protection

Encrypted PHI payloads
Patient-only reports
Per-user RAG
Privacy export
Health-data deletion

Auditability

Audit hash chain
IP/user-agent metadata
Consent records
Report versions
Doctor review history

App Hardening

Security headers
Upload scan
Rate limits
LLM fail-closed
No prescribing

Compliance Status

- Current healthcare compliance readiness is approximately 60% for a pilot or controlled demo.
- The system includes consent, audit, privacy export/delete, PHI encryption, and access isolation controls.
- It is not yet production HIPAA-ready without BAA, KMS-managed keys, SIEM, penetration testing, formal risk assessment, malware scanning, backup evidence, and incident response procedures.

Pending Production Architecture Items

What remains before production healthcare deployment

Highest Priority Pending Items

- Deploy over HTTPS with managed PostgreSQL, private database networking, secure cookies, and platform-level rate limiting.
- Move secrets and encryption keys to AWS Secrets Manager, GCP Secret Manager, or Vault with KMS-backed rotation.
- Use production pgvector and a stronger embedding model, with prompt/version audit trails and PHI minimization.
- Integrate real malware scanning, OCR for scanned files, lab table extraction, and confidence scoring.
- Add SIEM/monitoring, immutable audit storage, backup/restore evidence, disaster recovery, and incident response.
- Complete legal/compliance work: BAA, HIPAA risk assessment, policy docs, and penetration testing.

Recommended Deployment Path

